ReTrust-OT V1 / RT8

How the score is calculated

28 October 2026. Higher scores indicate more favourable evidence under the selected settings. The score is a decision aid, not a probability that equipment is safe.

Z = T x I x A x H x U

Factor	What it measures	RT8 rule
T	Exploitation evidence	max(KEV, LEV, EPSS), floored for the service life by how the flaw is reached: wormable .50, other network .30, local .15, physical .05. Confirmed exploitation is 1.
I	Technical severity	CVSS base score / 10. A missing score counts as 1, so absence never lowers risk.
A	Attack access	Read from the flaw's own CVSS attack vector: 1 for a reachable path whose conditions are met; 0 for a verified block; otherwise [0,1].
H	Credible OT harm	Safety/environment 1; control .8; recoverable disruption .5; minor .2; no material harm 0. Unknown is [0,1].
U	Affected and unfixed	1 for affected, unpatched firmware; 0 for verified fixed or not affected; otherwise [0,1].

Reachability comes from the weakness, not the topology

Select isolated, OT-only, IT-OT, remote vendor access, direct Internet or unknown. The answer is recorded as context and never moves the score: isolated, IT-OT and direct Internet all produce an identical range. An isolated controller may still be accessible from a compromised industrial workstation. A is settled instead by each weakness's own attack vector and the conditions it demands: an affected service reported reachable resolves a network or adjacent flaw, but a local or physical one also needs execution on the box or hands on the cabinet, so it stays unresolved until an operator confirms the attacker can meet what that weakness requires.

ReTrust does not scan the network. Site answers are operator-reported and need supporting evidence. A firewall changes attack access; it does not count as installing a firmware patch.

CVSS severity enters as I, never through H. An engineer must establish the credible effect of the particular weakness, rather than assigning every weakness the importance of the whole plant.

A worked calculation

Illustrative inputs, calculated by the production scoring functions. These are not findings about an actual PLC.

Input	Value	Reason
T	0.60	max(KEV 0, LEV .60, EPSS .12) is above the wormable floor of .50
I	0.98	CVSS 9.8 / 10
A	1	Path reachable; the flaw demands no extra conditions
H	0.80	Credible major loss of process control
U	1	Selected firmware affected and not patched

```
Z1 = 0.60 x 0.98 x 1 x 0.80 x 1 = 0.4704
```

The highest contribution counts fully

```
R = min(1, Z1 + .20 Z2 + .10 Z3)
E = 100 x (1 - R)
```

Contributions	R	Exposure safety E
0.4704	0.4704	52.96
0.4704 and .20	0.5104	48.96
0.4704, .20 and .10	0.5204	47.96

Repeated advisory records for one CVE count once. Different CVEs are review units, not proof of independent attack paths. An engineer can explicitly group a reviewed shared path. Only the largest three units contribute; R clips at 1.

Combine the four pillars

```
S = E^.60 x P^.20 x V^.15 x C^.05
```

With E=47.96, P=70, V=80 and C=60: **S = 56.48/100**. The current 80/60 bands give AVOID, assuming verified inputs and no mandatory blocker.

Unknown means VERIFY

If only U is unknown in the worked weakness, Z is between 0 and 0.4704. Exposure safety is between 52.96 and 100. ReTrust carries the bounds into the final score and lists the checks needed before deciding. It does not guess a middle value.

Example from the local index

ABB AC 800M: VERIFY; provisional score range **70.1-87.7/100**. No deployment or firmware inputs were supplied. Rebuild this sheet against a changed index to refresh the example.

Next check	Who can help
Network context and attack access	Network or OT security owner
Credible consequence of each weakness	Operations or safety engineer
Affected firmware and installed fixes	Asset owner or product supplier
Missing exploitation data	Security analyst; refresh public sources

Decision rules

PREFER: 80 or higher. CONDITIONAL: 60 to below 80. VERIFY: material evidence remains unresolved. AVOID: below 60 or a mandatory blocker. Bands read the score as displayed, to one decimal. A product with no usable evidence is VERIFY across its full range, with the conservative low end as the headline; a named firmware outside every published affected range is scored at exposure 100 instead.

Pillars enter the final product with a floor of 1. Missing patch, vendor or certification evidence keeps its full weight and enters at a neutral 50, so absent evidence never lifts a score. Unknown exposure stays in the range. Measured certification participates directly. Unfixed hardcoded credentials cap the result below PREFER.

Evidence and limits

Save JSON or HTML to retain RT8 settings, factor bounds, advisory citations and source capture dates. Per-finding reviews can retain rationale and evidence. Website answers apply across the findings in scope; review findings individually when their consequences or controls differ.

The weights, OT consequence values, service-life threat floors and multiplication are proposed ReTrust design choices that require validation. Historical benchmarks from earlier scoring models do not validate RT8 procurement decisions. KEV, LEV and EPSS have different time horizons; their maximum is a threat-priority index, not a calibrated compromise probability.